

개선요구 및 권고

제 목 쇼핑몰 유지관리 업무 및 보안취약점 개선에 관한 사항

소 관 부 서(기관) ★★★★★처

조 치 부 서(기관) ★★★★★처

내 용

1. 업무 개요

★★★★처는 「직제 규정 시행세칙」에 따라 공사의 경영정보시스템을 담당하는 부서로서 쇼핑몰 시스템의 유지관리 업무를 수행하고 있으며, 온라인 영업활동 지원을 위해 2021년도 신규 쇼핑몰 개발 용역사업을 추진하고 있다.

2. 판단 기준

「정보화업무 규정」 제20조(정보시스템 운영 및 유지관리)에 따르면 ★★★★★처는 정보화사업 성과물인 정보시스템을 유지·관리하는 부서로서 시스템의 적절한 유지관리를 위해 정기적 예방점검, 문제점 발생 시 복구 조치 및 유지관리 내용과 그 결과를 기록·관리하도록 되어 있으며, 「같은 규정」 제24조(정보시스템 장애 예방 및 대응 등)에 따르면 시스템 취약점 등 장애 발생요인과 관련하여 이를 예방하고 장애발생 시 대응하도록 되어 있다.

따라서 ★★★★★처는 관련 규정에 따라 정보시스템의 유지관리 내역과 결과를 기록·관리하여야 하고, 그 기록은 기능개선, 취약점 조치, 데이터 변경, 장애처리 등 구체적인 조치 내용과 유지관리 현황을 파악할 수 있도록 관리하는 것이 바람직하다.

또한 쇼핑몰 시스템의 보안상 취약점을 발견한 경우에는 즉각적인 대책 마련 및 보완 조치를 통해 향후 발생할 수 있는 문제점을 사전에 차단할 필요가 있다.

3. 감사결과 확인된 사항

2021. X. X. 감사일 현재 쇼핑몰 시스템의 유지관리 현황을 점검한 결과 ★★★★★처는 유지관리업체로부터 월간 보고서를 받아보는 방식으로 유지관리 내역을 관리하고 있었다.

그런데 해당 보고서에는 요청사항이 개조식으로 간략히 기재되어 있고 조치사항은 “완료”라고만 기재되어 있어 문제의 정확한 원인, 조치방법 등 세부 내용은 확인할 수 없었고, 심지어 서버다운 사태가 발생하였던 ‘2020년 ○○○○세트 판매’ 시점인 XX월 유지 보수대장에도 해당 문제에 대한 원인분석이나 조치결과가 없어 요구사항이 적절하게 조치되었는지 검증하기 어려운 실정이다. 그리고 월간 유지관리 보고서 외에는 시스템 장애이력에 대한 별도의 관리체계도 부재하였다.

또한 사업부서 등 쇼핑몰 시스템을 사용하는 관련부서에서 ★★★★★처를 통하지 않고 유지관리업체에 직접 개선 조치를 요구하는 경우에는 ★★★★★처가 해당 요구사항을 인지하지 못하여 유지관리 업무를 총괄적으로 관리하지 못할 우려가 있다.

따라서 ★★★★★처는 시스템 장애발생 이력을 포함하여 구체적인 유지관리 내용을 확인·검증할 수 있도록 유지관리 내역 및 결과를 보다 상세한 자료로 관리할 필요가 있고, 유지관리 수행부서로서 관련부서로부터 요구사항을 접수 받아 유지관리업체에 개선을 요청하고 적절한 조치가 이루어졌는지 그 조치결과를 확인·검증하여 총괄적 관리가 가능하도록 업무처리 프로세스를 정립할 필요가 있다.

한편 감사기간 중 현재 운영 중인 쇼핑몰 시스템을 점검한 결과 ‘2021년도 ○○○○세트’ 판매 과정에서 보안상 취약점이 있었던 것으로 확인되었다.

따라서 새롭게 구축하는 쇼핑몰 시스템은 향후 비정상적인 접속 시도 및 우회접속 등을 차단할 수 있도록 보안상 취약점을 전면적으로 검토하여 보완하고, 구축 완료 후

에는 통합테스트를 실시하여 요구한 기능이 적절히 구현되는지, 시스템 상에서 기타 문제점이 발생하지 않는지 여부를 검증할 필요가 있다.

관련부서(기관) 의견 ★★★★★처는 감사결과를 수용하면서 시스템 장애이력, 변경 이력 등을 체계적으로 기록·관리하기 위해 별도의 정보시스템 변경내역서를 작성·관리 하겠다는 의견을 제시하였고, 보안상 취약점에 대해서는 현재 운영 중인 쇼핑몰 시스템 에서 발견된 문제점들이 발생하지 않도록 새로운 쇼핑몰 시스템을 검증하고 개발 완료 하겠다는 의견을 제시하였다.

조치할 사항

★★★★★처장은

새로운 쇼핑몰 시스템 구축 시 비정상적 접속 시도 및 우회접속 등이 차단될 수 있도록 관련부서와 협의하여 보안상 취약점을 점검하고 보완하시고(개선)

쇼핑몰 시스템 장애이력을 포함하여 시스템 개선사항과 조치결과를 상세히 확인할 수 있도록 유지관리 체계를 개선하고 관련 업무를 총괄하며, 쇼핑몰 등 정보시스템 장애 발생 시 위기대응 기구를 설치, 즉각적인 원인분석 및 대응을 통한 조속한 정상화 뿐 아니라 그 처리결과를 기록하고 전파함으로써 향후 유사사례가 재발하지 않도록 「정보화 업무 규정」 및 「위기대응 매뉴얼(경영정보시스템 기능 마비)」을 정비하는 등 관련 업무 체계를 정립하시기 바랍니다.(권고)